

# Podręcznik właściciela

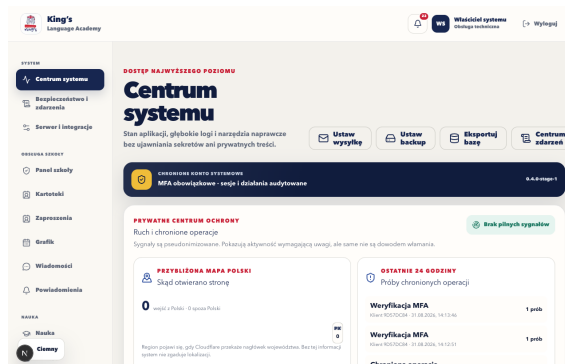
Pierwsze uruchomienie, serwer Raspberry Pi, szyfrowanie, kopie, odtwarzanie, aktualizacje i diagnostyka.

Dla kogo jest ten poradnik?

Wyłącznie dla właściciela technicznego. Tego pliku nie przekazuj zwykłym użytkownikom szkoły.

## Co zmieniło się od poprzedniej wersji

- Odwiedziny są liczone osobno dla anonimowych klientów; różne adresy nie tłumią swoich wejść.
- Retencja diagnostyki: odwiedziny 30 dni, audyt 180 dni, nieaktywne liczniki prób 7 dni. Codzienne przetwarzanie ma ograniczone partie.
- Diagnostyka przeglądarki zbiera wyłącznie ostrzeżenia i błędy: maksymalnie 60 wpisów przez 30 minut, z ograniczeniem powtórzeń.
- Logi systemowe pozostają ograniczone do 256 MB i 14 dni. Dane biznesowe mają oddzielne zasady retencji.
- Aktywne lokalizacje z kartotek są automatycznie widoczne na stronie szkoły.
- Zaktualizowano zależności z poprawkami wykrytymi przez audyt wydania, w tym Next.js, sharp i Nodemailer.



Wersja 1.1.3 · 12 września 2026

Zrzuty pokazują wyłącznie bezpieczne dane demonstracyjne.

# Najważniejsza odpowiedzialność

Konto właściciela ma najwyższe uprawnienia techniczne. Służy do utrzymania systemu, nie do codziennej pracy szkoły.

Nigdy nie przechowuj razem

Hasła LUKS, klucza recovery LUKS, klucza AGE do kopii, kodów MFA i samej kopii. Co najmniej jeden komplet odzyskiwania trzymaj poza Raspberry Pi.

## Cztery różne sekrety

- hasło główne LUKS — otwiera zaszyfrowany dysk
- klucz recovery LUKS — awaryjnie otwiera dysk
- klucz AGE — odszyfrowuje eksporty i backupy, ale nie dysk
- klucz automatycznego startu — root-only na karcie systemowej; uruchamia serwer po zaniku prądu

# Pierwsze uruchomienie

Pusta instalacja ma jednorazowy kod i nie zawiera szkoły ani kont. Pierwsza osoba staje się właścicielem systemu.

## Krok po kroku

- 1. otworzyć /pierwsze-uruchomienie
- 2. wpisać kod, nazwę szkoły, imię, e-mail i mocne hasło
- 3. ustawić i przetestować SMTP albo świadomie przejść bez poczty
- 4. zapisać klucz odzyskiwania pokazany tylko raz
- 5. skonfigurować MFA i zapisać kody awaryjne
- 6. dopiero potem zaprosić dyrektora i pozostałe role

## Ważne ograniczenia

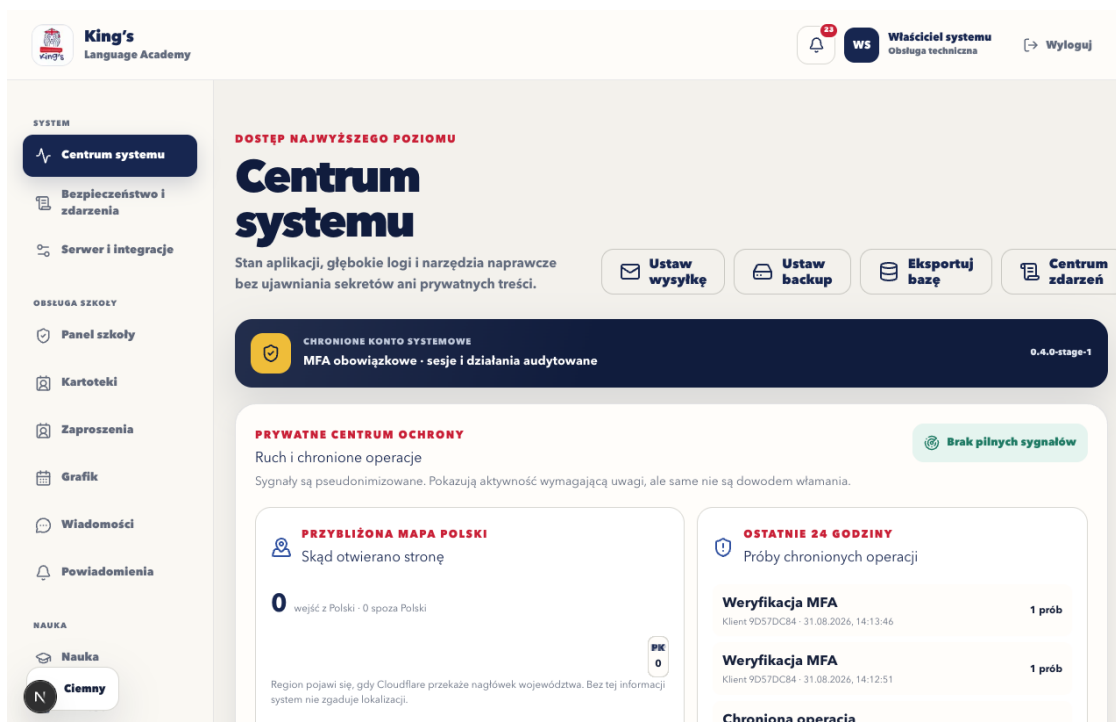
- kod instalacyjny działa tylko raz
- bez SMTP nie działają zaproszenia, reset hasła i e-maile
- utworzenie pierwszego konta bez poczty jest możliwe tylko dzięki fizycznie kontrolowanemu kodowi
- klucza odzyskiwania nie można odzyskać z publicznej strony

Najprostsza zasada

Najpierw klucze i MFA, potem poczta, następnie pierwsze zaproszenia.

# Centrum systemu

To pulpit stanu Raspberry, usług, dysków, aktualizacji i integracji.



## Krok po kroku

- 1. sprawdzić aplikację, PostgreSQL, nginx, Cloudflare i antywirusa
- 2. zobaczyć temperaturę, pamięć, dyski i stan zasilania
- 3. sprawdzić datę ostatniej kopii i testu odtworzenia
- 4. uruchomić kontrolowany restart lub test
- 5. przejść do bezpieczeństwa, logów i ustawień

## Ważne ograniczenia

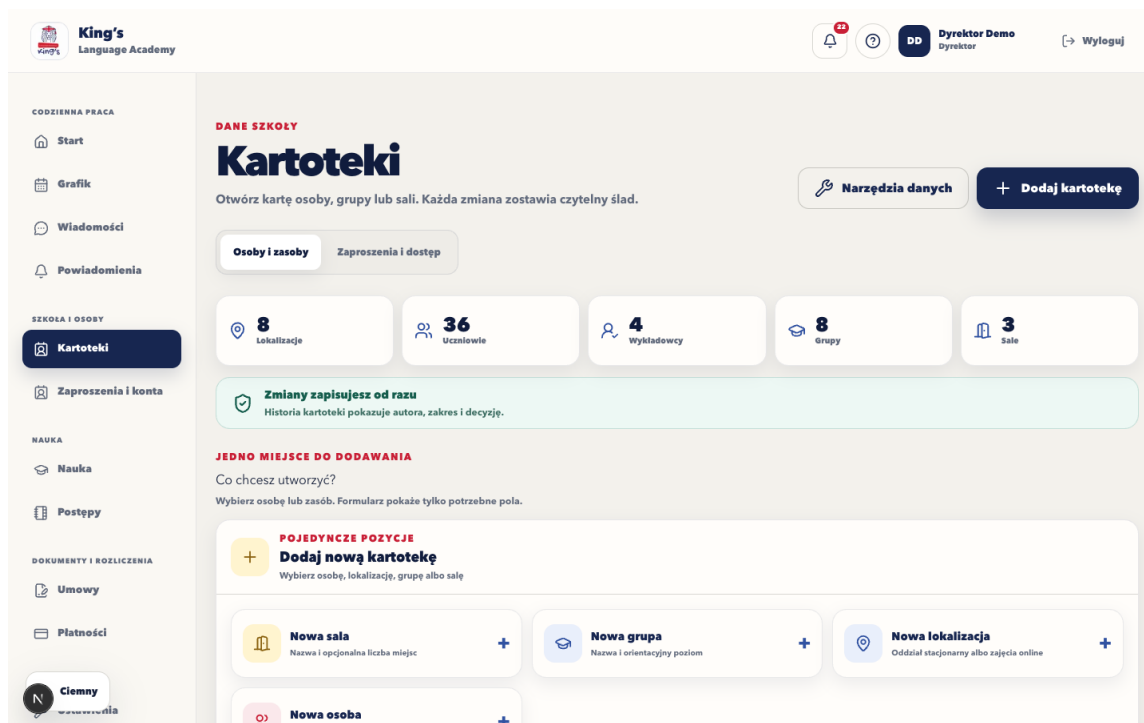
- historyczne flagi zasilania nie znikają po poprawie zasilacza
- temperatura i komunikat o undervoltage wymagają działania sprzętowego
- panel nie udostępnia ogólnej powłoki SSH ani dowolnych poleceń root

Najprostsza zasada

Wszystkie zielone usługi nie wystarczą: sprawdź także kopię, odtworzenie, auto-start i zasilanie.

# Konta, kartoteki i awaryjny reset hasła

Właściciel widzi wszystkie kartoteki szkoły, w tym archiwalne, i może pomóc każdej roli odzyskać dostęp bez poznawania starego hasła.



## Krok po kroku

- 1. otworzyć Kartoteki i przełączyć widok na aktywne albo archiwalne
- 2. wyszukać osobę i otworzyć jej kartę
- 3. wybrać standardowy link resetu wysyłany e-mailem
- 4. w awaryjnej sytuacji wygenerować hasło tymczasowe
- 5. skopiować je tylko raz albo wysłać przez skonfigurowane SMTP
- 6. przywrócić omyłkowo zarchiwizowaną kartotekę

## Ważne ograniczenia

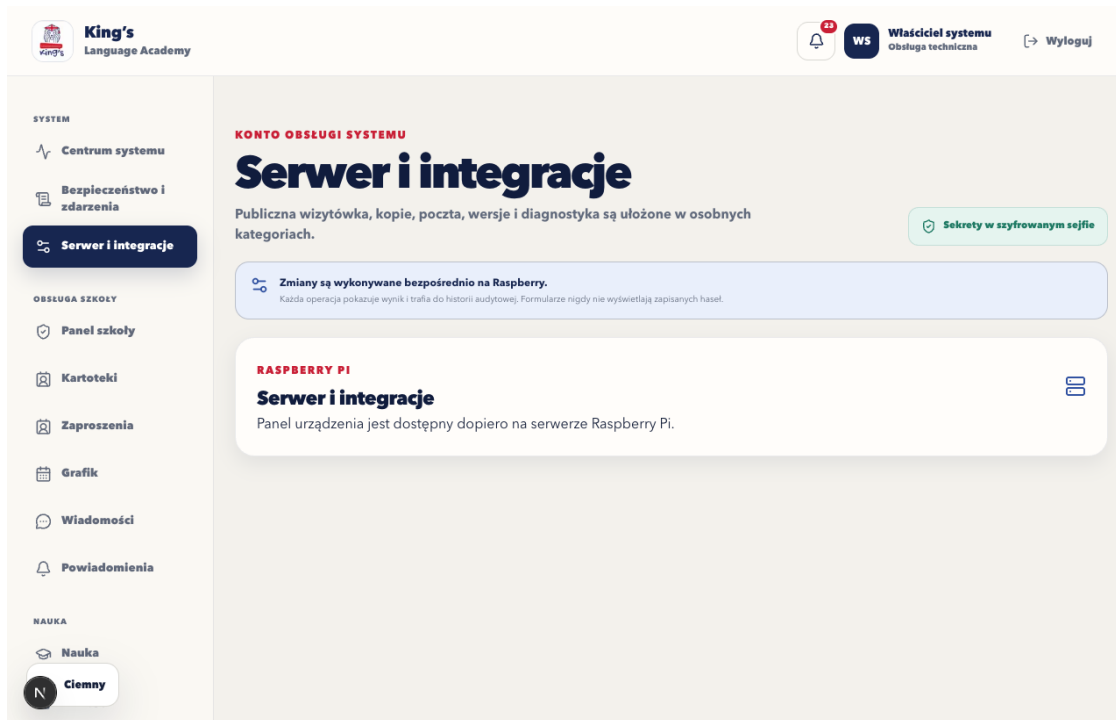
- hasło tymczasowe wygasa po 30 minutach
- wszystkie dotychczasowe sesje tej osoby są zamykane
- po pierwszym logowaniu system wymusza ustawienie własnego hasła
- starego hasła nie da się podejrzeć
- wycofanie kartoteki nie usuwa umów, płatności ani audytu

### Najprostsza zasada

Zwykły link e-mail jest wariantem zalecanym. Hasło tymczasowe przekazuj prywatnym kanałem wyłącznie właściwej osobie.

# Serwer, integracje i moduły ról

Ustawienia techniczne są pogrupowane według celu: widoczność funkcji, poczta, backup, eksport/import, tryb publiczny i kontrolowane operacje.



## Krok po kroku

- 1. w macierzy modułów pozostawić włączone tylko funkcje używane przez każdą rolę i zapisać zmianę
- 2. osobno zdecydować, czy dyrektor może edytować stronę i wykonywać masowy import lub eksport; transfer danych jest domyślnie wyłączony
- 3. sprawdzić panel wybranej roli; wyłączony moduł znika z menu, pulpitu i samouczka
- 4. zapisać SMTP dopiero po prawdziwym teście wysyłki
- 5. wybrać wykryty, zamontowany dysk USB
- 6. ustawić harmonogram i retencję
- 7. skonfigurować SFTP z weryfikacją odcisku
- 8. pobrać pełny zaszyfrowany eksport
- 9. wgrać kopię i zweryfikować kluczem
- 10. przełączyć stronę szkoły i prezentację produktu

## Ważne ograniczenia

- wyłączenie modułu nie kasuje jego danych
- właściciel zawsze zachowuje dostęp naprawczy
- Start, logowanie, MFA, pomoc i zgłoszenie problemu pozostają dostępne
- import, eksport i zapis strony sprawdzają uprawnienie również na serwerze
- aplikacja działa z NoNewPrivileges i nie wykonuje sudo

- operacje systemowe przechodzą przez zamknięty broker z listą dozwolonych akcji
- SSH pozostaje prywatnym kanałem operatora, nie terminalem w przeglądarce

#### Najprostsza zasada

Po zmianie macierzy sprawdź konto każdej dotkniętej roli. Jeżeli formularz serwera zwróci błąd, nie obchodź go ręcznym `chmod` lub szerokim `sudo` — sprawdź usługę `kla-web-control`.

# Co dokładnie zawiera pełna kopia

Pełny eksport jest tym samym, zweryfikowanym formatem co kopia serwerowa.

- pełny pg\_dump PostgreSQL: szkoła, konta, role, kartoteki, relacje, grupy, sale, grafik, obecności, umowy, raty, materiały, postępy, wiadomości, powiadomienia, statystyki i audyt
- private-files: PDF-y, podpisane skany, materiały, zdjęcia i załączniki
- manifest z czasem oraz commitem aplikacji
- zaszyfrowane sekrety ciągłości aplikacji, bez prywatnego klucza AGE

## Weryfikacja 1:1

Test sprawdza SHA-256, odszyfrowuje archiwum, odrzuca niebezpieczne ścieżki, skanuje pliki ClamAV i wykonuje prawdziwe pg\_restore do tymczasowej bazy. Dopiero później pozwala zatwierdzić odtworzenie.

## Pobranie na komputer

- wybierz „Przygotuj kopię do pobrania”
- pobierz plik .tar.age oraz zachowaj sumę SHA-256
- pobieranie obsługuje Range, więc przeglądarka może wznowić transfer
- link wygasa po 24 godzinach

## Import i odtworzenie

- wybierz plik i wpisz właściwy klucz AGE
- poczekaj na pełny test bez zamykania strony
- porównaj datę, commit i sumę
- zaznacz potwierdzenie i dopiero wtedy uruchom odtworzenie
- serwer najpierw wykonuje kopię bieżącego stanu i ma automatyczny rollback



# Logi i bezpieczeństwo

Dziennik właściciela łączy zdarzenia aplikacji, ruch, alarmy i stan serwera bez pokazywania sekretów.

The screenshot shows the 'King's Language Academy' system owner interface. The top navigation bar includes the logo, a notification bell with 23 alerts, a 'WS' (Właściciel systemu) button, and a 'Wyloguj' (Logout) link. The left sidebar contains a 'SYSTEM' section with 'Centrum systemu' and 'Bezpieczeństwo i zdarzenia' (selected), and an 'OBSŁUGA SZKOŁY' section with 'Panel szkoły', 'Kartoteki', 'Zaproszenia', 'Grafik', 'Wiadomości', and 'Powiadomienia'. The main content area is titled 'TYLKO WŁAŚCICIEL SYSTEMU' and 'Centrum zdarzeń'. It features three summary cards: 'Operacje' (84, last 24h), 'Wyświetlenia' (47, last 24h), and 'Aktywni wykonawcy' (2, unique accounts). Below these are filter options for 'Rodzaj zdarzeń' (Operacje i zmiany), 'Szukaj' (akcja, osoba lub obiekt), 'Okres' (7 dni), 'Moduł' (Wszystkie moduły), 'Rola' (Wszystkie role i goście), and 'Źródło' (Wszystkie szkoły i produkt). A 'Zastosuj filtry' button is present. The bottom section shows '167 zdarzeń - strona 1 z 3' and a table with columns for date/time, system details, and user information.

## Krok po kroku

- 1. filtrować po czasie, rodzaju akcji, koncie, adresie i wyniku
- 2. otworzyć szczegóły pojedynczego zdarzenia
- 3. sprawdzić mapę przybliżonego źródła ruchu
- 4. odróżnić kontrolowany 401/403/429 od awarii 5xx
- 5. zobaczyć próby naruszeń jako alerty najwyższego priorytetu
- 6. eksportować bezpieczny raport dla analizy

## Ważne ograniczenia

- geolokalizacja IP jest przybliżona
- logi nie mogą zawierać haseł, tokenów, treści rozmów ani pełnych danych dzieci
- publiczny challenge nie upoważnia do łamania prawa ani uzyskiwania trwałego dostępu

### Najprostsza zasada

Najpierw zabezpiecz dowody i sprawdź audyt. Nie kasuj logów przed wyjaśnieniem zdarzenia.

# Auto-start i watchdogi

Po zaniku prądu system ma sam otworzyć sejf kluczem root-only, uruchomić bazę, aplikację, proxy i tunel.

- systemd Restart=always dla aplikacji
- osobny restart tunelu Cloudflare
- minutowy healthcheck usług i bazy
- sprzętowy watchdog systemd
- trwały journal poprzedniego uruchomienia
- timery kopii, retencji, testu odtworzenia i kolejki e-mail

Test po wdrożeniu

Uruchom audyt startu, kontrolowany reboot i ponownie audyt. Awaryjne odłączenie zasilania testuj wyłącznie na kopii i po bezpiecznym zamknięciu procesów zapisu.

## Planowany restart aplikacji

Otwórz Ustawienia właściciela, odszukaj sekcję Automatyczny restart aplikacji. Wybierz Codziennie lub Co niedzielę, wpisz godzinę i minuty według czasu polskiego. Zaznacz potwierdzenie i kliknij Zapisz harmonogram restartu. Po odświeżeniu sprawdź zapisany wybór. Wyłączony oznacza brak zaplanowanych restartów, a nie wyłączenie watchdogu.

Wybierz porę poza lekcjami. Restart dotyczy tylko aplikacji: nie wyłącza PostgreSQL, tunelu ani Raspberry. Niezapisany formularz może wymagać ponowienia. Operacja jest pomijana podczas backupu, importu i aktualizacji, bez kompletnej kopii z ostatnich 48 godzin lub w ciągu 15 minut od poprzedniej próby. Pominięty termin nie jest nadrabiany po włączeniu urządzenia.

## Kontrola pamięci Linux

Po uruchomieniu Raspberry zaczekaj na dysk: system może czekać do 180 sekund. Audyt sprawdza także obecność systemd-cryptsetup, a watchdog ponawia montowanie i uruchamia panel sterowania. Jeżeli mimo tego jest błąd, nie formatuj dysku i nie zmieniaj kluczy. Sprawdź zasilanie dysku oraz pełny audyt startu.

Jeżeli widzisz, że systemowa kontrola pamięci nie jest aktywna, sam restart aplikacji nie wystarczy. Operator przygotowuje konfigurację startową i po kopii oraz audycie wykonuje kontrolowany restart całego urządzenia. Potem sprawdza kontroler memory oraz liczbowy pomiar MemoryCurrent. Sam zapis limitu w pliku usługi nie potwierdza jego działania.

## Gdy sejf nie wstanie

- nie formatuj dysku
- sprawdź, czy system widzi właściwy UUID
- użyj hasła LUKS lub recovery LUKS — nie klucza AGE
- po otwarciu uruchom audyt startu
- wykonaj nową kopię i test odtworzenia

# Aktualizacje bez utraty danych

- wydanie powstaje z czystego, przetestowanego commita
- pakiet ma podpisany manifest i dokładne sumy
- przed migracją powstaje backup z testem odtworzenia
- migracje są rozszerzające i stosowane przez Prisma
- build powstaje w katalogu .new
- po healthchecku następuje atomowe przełączenie
- błąd uruchamia rollback aplikacji i bazy

Nigdy z panelu

Nie wykonuj npm update, apt upgrade ani dowolnych poleceń powłoki z przeglądarki. Panel może pokazać stan wersji i uruchomić wyłącznie podpisaną, wcześniej przygotowaną aktualizację.

## Minimalna checklista wydania

- npm run check
- npm run build
- telefon 375 × 812 i komputer 1440 × 900
- brak błędów konsoli
- npm audit: 0 znanych podatności produkcyjnych
- npm run package:release i package:raspberry
- backup + realny test restore
- wdrożenie dokładnego commita
- publiczny HTTPS, logowanie i role
- reboot i ponowny status

# Plan awaryjny

Kolejność działań ma znaczenie. Najpierw chroń dane, potem przywracaj usługę.

## Aplikacja nie odpowiada

- sprawdź stan usług
- sprawdź sejf i PostgreSQL
- uruchom kontrolowany restart aplikacji
- sprawdź healthcheck lokalny i publiczny
- otwórz logi bieżącego i poprzedniego bootu

## Podejrzenie włamania

- nie usuwaj zdarzeń
- zapisz czas i identyfikator alertu
- zablokuj narażone konto i unieważnij sesje
- zmień naruszone sekrety innym, bezpiecznym kanałem
- sprawdź integralność wydania i bazy
- w razie danych osobowych uruchom procedurę incydentu RODO

## Awaria dysku

- nie zapisuj dalej na uszkodzonym nośniku
- przygotuj nowy zaszyfrowany wolumen
- zainstaluj zgodną wersję aplikacji
- wgraj kopię, podaj klucz AGE i wykonaj test
- odtwórz, sprawdź liczby rekordów oraz pliki
- dopiero potem przełącz ruch

### Stan sprzętu

Raspberry zgłasza historię problemów z zasilaniem. Przed produkcją wymagane są stabilny zasilacz, chłodzenie i najlepiej UPS. Oprogramowanie nie naprawi spadków napięcia.